

Industrial Security (Bachelor)

Exercise Sheet – Section 06 Vulnerabilities and Assessment

These exercises put you in the seat of an OT vulnerability analyst. Each question is scenario-driven: you must reason about advisories, tooling, scanning safety, and patch politics rather than recite definitions. Three to ten clear sentences (or a short table / command line) are enough per item. Cite vendors, tools, and standards by their real names.

Exercise 6.1 – CVSS v3.1 Environmental Score

A vendor PSIRT publishes a critical advisory for a programmable logic controller (PLC) used in your plant. The base vector is `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` (base score 9.8). The affected PLC sits in cell zone L2, reachable only from the engineering VLAN through a stateful firewall that allows TCP/102 from two engineering workstations. The controller runs a non-safety dosing loop; an integrity loss would spoil a batch but cannot injure personnel.

1. State the base vector again and compute (or recall) the base score.
2. Choose justified environmental modifiers. Address at minimum MAV, MAC, MPR, and the security requirements CR, IR, AR. Briefly justify each choice in one sentence.
3. Give the full environmental vector and the resulting score (use the FIRST online calculator or show the formula step).
4. In two sentences: does the environmental score change your patch priority compared to the base 9.8?

Exercise 6.2 – 200 PLCs vs. CISA in 24 Hours

Your asset owner hands you a spreadsheet with 200 PLCs across four sites: columns are *site*, *cell*, *vendor*, *model*, *firmware*, *IP*, *owner*. A new campaign of CISA ICS advisories drops overnight. You have one working day to tell management which devices are affected.

1. List the data fields you must have on each PLC *before* you can match against an advisory.
2. Name the feeds you would pull (CISA, vendor PSIRTs, NVD) and the format in which each is published.
3. Sketch the tooling chain end-to-end. Real tool names only, e.g. Claroty CTD, Nozomi Guardian, Dragos Platform, Tenable.ot, Forescout SilentDefense, Microsoft Defender for IoT, or a scripted pipeline using the NVD JSON API.
4. State two things that will go wrong on a first run and how you mitigate them (firmware naming mismatches, EOL devices, advisories without machine-readable affected ranges, ...).

Exercise 6.3 – When Active Scanning Wins

Passive monitoring (e.g. Nozomi Guardian on a SPAN port) is the production-safe default for an operating plant. Yet there are situations where an *active* scan is the right call.

1. Justify in three to five sentences why active scanning is sometimes unavoidable for an accurate inventory or CVE match.

2. Give *two* concrete scenarios where you would choose active over passive (e.g. FAT/SAT on a new skid, post-incident forensics on an isolated cell, firmware verification during a planned outage). For each, state the safeguard that keeps the scan from disturbing production.

Exercise 6.4 – Annotated Safe-nmap Command

You have an isolated bench network with one test PLC at 192.168.10.10. Write the `nmap` command line you would run, then annotate every flag in one short line.

1. Provide the command (single line, all flags).
2. For each flag, state in one sentence *what it does* and *why it matters for a PLC*.
3. Add one sentence on why the same command must *not* run on a production cell, even if you are sure of the IP range.

Cover at minimum: scan technique, rate limit, scan delay, ping behaviour, port selection, and one NSE script appropriate for the target.

Exercise 6.5 – Read a Real CISA Advisory

Pick one current CISA ICS advisory (any ICSA-25-XXX-XX or ICSA-26-XXX-XX from the CISA advisories archive). Extract and write down:

1. Affected vendor, product family, and firmware range.
2. The CWE(s) cited and the CVSS v3.1 base vector and score.
3. Recommended mitigations, split into *patch* and *non-patch* (network, configuration, monitoring).
4. Vendor patch availability: is fixed firmware shipping today, and if not, what is the published timeline?
5. In two sentences: would you treat this advisory as urgent for a small water utility versus a tier-1 chemical site, and why?

Cite the advisory by its full ID and publication date.

Exercise 6.6 – Spot the Misconception: Nessus on Tuesday

A junior consultant proposes running *Nessus* “safe checks” against the plant network next Tuesday afternoon, arguing that the safe-checks profile cannot harm devices.

1. Give three concrete reasons this plan is dangerous in an OT environment. Reference at least one real-world failure mode (e.g. legacy stack crashes on unexpected TCP flags, broadcast storms from credentialed scans, SCADA HMI lock-out from repeated login probes).
2. Propose one alternative that achieves a comparable inventory / vulnerability view without the risk. Name a specific tool or method.

Exercise 6.7 – Honeypots in OT

Conpot is the canonical open-source ICS honeypot. GasPot mimics a Veeder-Root tank gauge.

1. In three to four sentences, describe what Conpot is and what protocols it can emulate by

default.

2. Where would you deploy it in a Purdue-segmented plant network (which zone, which IP space) so that any hit on it is unambiguously malicious?
3. Name two activities a Conpot deployment *would* catch and two it *would not* catch (be specific about attacker sophistication).

Exercise 6.8 – Patching Cadence: Schneider PLC, 8-Month Window

A critical CVE is published against a Schneider Electric Modicon PLC in your plant. The vendor patch ships within three weeks, but the next planned production outage that allows the affected cell to be taken offline is eight months away.

1. Write a one-paragraph compensating-control proposal that bridges the gap. Cover network, monitoring, and process controls. Reference at least one specific control product or technique (IPS rule, Tofino zone, firewall rule tightening, EDR on engineering workstations, Claroty Continuous Threat Detection alerting, ...).
2. Write a one-paragraph escalation argument you would deliver to plant management *if* those compensating controls cannot be implemented in full. State what acceptance of residual risk requires (who signs, against which standard).

Exercise 6.9 – Researcher Drops a 0-Day on You

A friendly independent researcher emails your security inbox with a working 0-day exploit against a Schneider EVlink charger used on your campus. They say they have *not* notified Schneider PSIRT.

1. Describe the next four steps you would take, in order, in the first 48 hours.
2. For each step, state the rationale: who you involve, what you avoid (e.g. do not run the exploit against production, do not publish), and why.
3. Reference one published coordinated-disclosure framework that guides this workflow (e.g. ISO/IEC 29147, CERT/CC guidance, or FIRST PSIRT Services Framework).

Exercise 6.10 – CWE-798 Hard-Coded Credentials in the Wild

CWE-798 (use of hard-coded credentials) is consistently among the most common root causes in ICS advisories.

1. Give *three* concrete examples from real CISA advisories or vendor PSIRTs (any vendor: Siemens, Rockwell, Schneider, ABB, Mitsubishi, Moxa, ...). For each, name the product, the advisory or CVE ID, and one sentence on the impact.
2. Propose *one* organisation-level mitigation that reduces the harm even before the vendor ships a patch. Be specific: which zone, which control, which monitoring rule.